Compliance Facts Register — Setnayan

Date: 2026-07-05 · **Revised 2026-10-22** (DPO contact, scale caveat, sub-processors rebuilt from the code, payment rail, remaining unknowns)
Purpose: The single source for every `[TO CONFIRM]` value across the NPC pack. Owner-supplied facts + values I could derive (live DB / code / known infra). Finalize with the DPO (the owner/proprietor) + PH counsel, then thread into the pack (or maintain via the admin Compliance page — see note at end).

> [OK] **The BIR TIN has been REDACTED from this file** (2026-07-05) — the sensitive government ID now lives only in the access-controlled **admin → Compliance** page (PR #2848), never in a repo. This file remains a working reference for the non-sensitive facts; still keep it out of any public repository.

---

1. Business identity — [OK] supplied

Field	Value
PIC (legal)	**SETNAYAN SOFTWARE DEVELOPMENT SERVICE** (sole proprietorship)
Proprietor	Indalecio Sacdalan Casasola II
DTI Business Name No.	8297508 (national · valid 25 Jun 2026 – 25 Jun 2031)
BIR TIN	**[redacted — held by owner; entered in admin → Compliance]** *(sensitive government ID; deliberately not stored in this file / any repo)*
Registered / principal address	**76 Sampaguita Avenue, Quezon City** *(barangay + ZIP — add if NPC form requires)*
NPC registration no.	*(blank until filed)*

2. DPO & team — [OK] supplied

Field	Value
DPO	**Indalecio Sacdalan Casasola II** (the proprietor/PIC also serves as DPO) · published contact **dpo@setnayan.com** (owner ruling 2026-09-22; verified reachable 2026-09-13; routes to the owner's iCloud) · **registered on the NPC DPO system 2026-07-07** under iscasasolaii@gmail.com — update to dpo@ at filing
DPO employment basis	Internal — the proprietor/PIC also acts as DPO (2-person founding team). (!) **PIC = DPO:** NPC generally prefers a DPO with autonomy from the controller; for a 2-person sole proprietorship this is commonly accepted — counsel to confirm and, if kept, note a short independence rationale in the designation sheet (doc 03).
DPO phone / designation date	*(to set — recommend stamping the date the manual is adopted)*

Total headcount	**2** — Indalecio S. Casasola II (proprietor + DPO) + Claire E. Buanhog (VP, co-founder)
Staff with personal-data access	Both (2 of 2)

3. Scale — (!) RE-READ FROM LIVE DB 2026-07-31 · the 2026-07-05 figures below are STALE AND HIGH

> (!) **2026-10-22: not re-measured.** The latest production reading in the pack is 2026-08-17 (9 accounts · 39 guests · 2 shops · 6 events · 0 face vectors). This session has no production access, so no newer count is given — read `/admin/compliance/data-sheet` on filing day.

Data subjects	2026-07-05 (stale)	2026-07-31 (live)
Customer accounts (`users`)	19	**6**
Vendors (`vendor_profiles`)	50	**2**
Guests (`guests`)	332	**39**
Events	61	**3**
Active biometric face vectors (sensitive)	**0**	**0** — `guest_face_enrollments` is empty (0 rows), `user_face_profiles` 0

> **(!) The counts went DOWN by roughly 10×, which means test data was purged at some point between 2026-07-05 and 2026-07-31.** Total data subjects today = **45** (6 accounts + 39 guests), **not the "~401" quoted in `00_ADOPTION_COVER_SHEET`** and echoed through docs 01/03. Those prose figures are labelled as a *2026-07-05 pre-launch snapshot*, which keeps them defensible as history — but **do not type them into an NPC form.**

> [OK] **The filing itself is safe:** `/admin/compliance/data-sheet` computes every scale count **live** at render time (`data-sheet/page.tsx` → `countOf()`), so the exported sheet reports whatever is true on the day it is generated. The risk is only that a human reads the prose instead of the export. **Re-read the counts on the day you file** — do not trust any number written in this pack.

> The registration-threshold analysis is **unaffected**: 45 subjects and 0 biometric vectors are further below the ≥1,000-SPI trigger than the stale figures were, and the recommendation to register still rests on the **risk-to-rights + not-occasional** grounds, which are volume-independent (doc 03 § B.4).

- **Sensitive-data holders today:** 0 biometric at the last reading; suppliers submit the TIN on BIR 2303 (government IDs retired 2026-07-03); guest `dietary_restrictions` may reveal health/religion (special category). Counts are small + pre-launch — but per the RoPA, **NPC registration is still advised** on the *risk-to-rights + not-occasional* grounds, independent of volume.

4. Breach response team — (!) currently the 2-person team

- No external DBRT members yet. Document the 2-person structure: **DPO = the proprietor (owner)** leads; **VP (Claire E. Buanhog)** supports. Add an external PH counsel liaison when engaged.
- 24/7 escalation contacts + DPO breach hotline: *(to set — even a single mobile + the DPO email suffices to start).*

5. Sub-processors — rebuilt 2026-10-22 from the hosts the code calls (`origin/main aceb080a0a`)

Sub-processor	Role	Jurisdiction / hosting	Personal data?	DPA on file
Supabase	Database, sign-in, realtime	**Singapore** (ap-southeast-1)	Yes — incl. face vectors	**No**
Vercel	App hosting	US company; functions in **Singapore** (`sin1`)	Yes (in transit)	**No**
Cloudflare	R2 storage (APAC) · TURN relay · Turnstile bot check · STUN	APAC / global	Yes (media, selfies, proofs, documents; IP in transit)	**No**
Resend	E-mail (no guest e-mail since 2026-09-29)	United States	Yes (addresses + content)	**No**
Sentry	Error monitoring, masked replay on error	United States	Minimal (scrubbed)	**No**
Anthropic	Receipt reading · Deep Search · gallery screening · theme sentence	United States	Yes (payment screenshots)	**No**
OpenAI	Moderation of published text	United States	Yes (text)	**No**
LanguageTool	Grammar check, free public API	Germany (EU)	Yes (text)	**No — not possible on free endpoint**
Google	Sign-in · YouTube · Drive · Gemini · STUN	United States	Yes, per connection	Google API terms
Apple	Sign in with Apple · in-app purchase (off) · iTunes search	United States	Yes (ID token; purchases)	Apple terms
Meta	Own posts · supplier Instagram sync	United States	Supplier posts	Meta terms
TikTok	Patiktok posting	SG / US	Yes, per connection	TikTok terms
OpenStreetMap · Vimeo · browser push services · public CDNs	Maps · poster image · web push · library downloads	UK / US / various	Address text, links, notification content, IP	n/a
~~PostHog~~	~~Product analytics~~	—	[X] **Removed 2026-10-22 (PR #6774)**	—
~~Persona / Veriff / Onfido~~	~~Vendor ID verification~~	—	[X] **Retired 2026-07-03**	—

Suno	Music, used by hand	—	**No** — not called by code	n/a
Face matching	Embedding + match	**In the browser + our own server function** (self-hosted open model); vectors in Supabase (Singapore). **No third-party face service.**	Yes (biometric, stored)	n/a (in-house)

6. Processing specifics — [OK] derived

Question	Answer
Sensitive RSVP fields collected	`dietary_restrictions` + `meal_preference` (may reveal health / religious belief — special category). **No standalone religion or health field.**
Solely-automated decisions w/ legal/significant effect	**YES — one, as of 2026-07-07:** the Anti-Fraud engine (DPIA **R-08** / ROPA **DPS-12**) can **automatically suspend** a vendor's public listing at a high fraud score (**reversible**). The **irreversible** wipe/ban is NOT automated (routed through the four-eyes admin gate). AI planning features remain assistive only. See `08_DPIA_AntiFraud_Trust_Integrity_2026-07-07.md` §6 (RA 10173 §16(c)/§34) — a formal contest/appeal path is a flagged follow-up.
Payment rail	**No gateway is called.** Manual apply-then-pay to Setnayan's own BDO / GCash accounts with a proof upload. Maya (dormant) was superseded by PayMongo as the chosen future rail (owner 2026-07-23) — **neither is called by the code**. Apple in-app purchase is built and switched off. (Updated 2026-10-22.)
Staff NDAs / privacy training / device policy	*(to set — for a 2-person team, a short signed confidentiality + basic-hygiene note suffices; recommend adopting.)*
DPIA / designation adoption dates	*(to set on adoption.)*

7. Remaining true unknowns (short list for owner/DPO + Claire/VP) — updated 2026-10-22

1. Barangay + ZIP for the address
2. The DPO contact phone + the adoption/signature date
3. Which sub-processors have a signed DPA (today: none) — task `t2-8`
4. Whether to adopt the light NDA / training / device-hygiene notes (recommended) — task `t2-11`
5. Production state that a session cannot read: data-subject counts, each `/admin/data-privacy` control, the `npc_filing_tasks` statuses, and which keys/switches are set (Google/Apple sign-in, Turnstile, TURN, push, Anthropic, device fingerprint)
6. ~~PostHog instance region~~ — retired: PostHog removed 2026-10-22

This register resolves the large majority of the pack's `[TO CONFIRM]` items. Recommended next step: move these facts into an access-controlled admin Compliance page (editable, admin-only, can export the NPC data sheet) — the correct secure home for the TIN + DPO details, rather than a plaintext file.